ЛЕКЦІЯ 4
СУЧАСНІ ДАТАСЕТИ ТА КІБЕРЗАГРОЗИ

ЗМІСТ

1. Вступ.
2. Класичні датасети: математичний апарат, обмеження та структура.
3. Огляд сучасних датасетів.
4. Поведінкові моделі сучасних кіберзагроз.
5. Висновки
6. Питання для самоконтролю

1. ВСТУП

У сучасних умовах стрімкого розвитку інформаційних технологій та цифрової трансформації суспільства питання забезпечення кібербезпеки набуває критичного значення. Одним із ключових інструментів побудови інтелектуалізованих систем інформаційної безпеки є використання методів машинного навчання, ефективність яких безпосередньо залежить від якості та актуальності навчальних даних. У цьому контексті особливу роль відіграють датасети, що моделюють або відображають поведінку комп'ютерних мереж у нормальних умовах та під час реалізації різноманітних кіберзагроз. Важливо підкреслити, що сам термін «датасет» (англ. dataset) у рамках цієї дисципліни означає структурований набір даних, який містить ознаки (features), що характеризують об'єкти спостереження, а також, у випадку задач із навчанням з учителем, мітки класів (labels), які відображають належність кожного об'єкта до певного типу поведінки, наприклад, нормальної активності або конкретного виду атаки.

Розширюючи це визначення, слід наголосити, що датасет у кібербезпеці — це не просто набір числових значень або записів, а складна модель реального середовища, яка включає як мережевий трафік, так і контекстні характеристики поведінки користувачів, систем та пристроїв. У більшості випадків сучасні датасети формуються на основі мережевих потоків (flows), що збирають інформацію про взаємодію між вузлами мережі протягом певного інтервалу часу. Кожен такий потік може включати десятки або навіть сотні ознак, серед яких часові характеристики, статистичні параметри, інформація про протоколи, обсяг переданих даних, частота пакетів тощо.

Окрім того, важливим аспектом є семантична інтерпретація даних. Наприклад, одна і та ж кількість пакетів може означати нормальну активність у випадку потокового відео або бути ознакою атаки типу DDoS у контексті веб-сервера. Таким чином, датасет повинен не лише відображати "сирі" дані, але й зберігати контекст їхнього використання, що суттєво ускладнює процес його побудови.

2. КЛАСИЧНІ ДАТАСЕТИ: МАТЕМАТИЧНИЙ АПАРАТ, ОБМЕЖЕННЯ ТА СТРУКТУРА

2.1. Математична постановка задачі виявлення вторгнень

Формально задачу виявлення кіберзагроз можна розглядати як задачу навчання відображення. Нехай існує множина об'єктів мережевого трафіку:

$$X = \{x_1, x_2, \dots, x_n\}, x_i \in R^d,$$

де x_i — вектор ознак мережевого потоку, а d — розмірність ознакового простору.

Кожному об'єкту відповідає мітка:

$$y_i \in \{0,1, \dots, k\},$$

де 0 — нормальна активність, 1...k — типи атак.

Задача класифікації полягає у знаходженні функції:

$$f(x) \to y$$

або ймовірнісної моделі:

$$p(y|x)$$

У випадку аномалій задача може бути сформульована як:

$$p(x) < \in \Rightarrow \text{аномалія}$$

Це означає, що ми фактично працюємо з нестаціонарним розподілом даних, де

$$P_t(x) \neq P_{t+1}(x),$$

що є формальним вираженням зсуву концепції даних у часі (термін, що буде описаний нижче) та призводить до деградації якості моделі машинного навчання.

2.2. Обмеження класичних датасетів (NSL-KDD)

Історично одним із найвідоміших і найширше використовуваних датасетів для досліджень у сфері виявлення вторгнень є NSL-KDD (Network Security Laboratory – Knowledge Discovery in Databases), який був розроблений як покращена версія попереднього датасету KDD Cup 1999. Проте, незважаючи на його популярність у навчальних курсах та наукових роботах, NSL-KDD має низку суттєвих обмежень, які роблять його малопридатним для моделювання сучасних кіберзагроз.

По-перше, він містить застарілі типи атак, характерні для кінця 1990-х років, що не відображають сучасні вектори атак, такі як складні багатоступеневі кампанії, атаки на хмарні інфраструктури чи IoT-системи. По-друге, значна частина даних у цьому датасеті є синтетично згенерованою, що призводить до спотворення статистичних властивостей реального мережевого трафіку. По-третє, NSL-KDD не враховує динамічну природу сучасних атак, пов’язану з явищем зміни розподілу даних у часі.

Додатково варто зазначити, що структура ознак у NSL-KDD є обмеженою і не включає багатьох сучасних характеристик, таких як поведінкові патерни користувачів, взаємодія між сервісами або контекстні дані з рівня застосунків. Це означає, що навіть при ідеальному навчанні модель, побудована на цьому датасеті, не здатна ефективно працювати в умовах реальних сучасних мереж.

Порівняння класичних і сучасних датасетів подано у таблиці 1.

Характеристика	**NSL-KDD**	**Сучасні датасети**
Період створення	1999–2009	2015–дотепер
Типи атак	Застарілі	Сучасні, багатовекторні
Реалістичність	Низька	Висока
Джерело даних	Частково синтетичні	Реальні/гібридні
Підтримка «Інтернету речей» (Internet of Things)	Відсутня	Присутня

Табл.1.Порівняння класичних і сучасних датасетів

Таким чином, навіть при ідеальному навчанні модель, побудована на цьому датасеті, не здатна ефективно працювати в умовах сучасних мереж.

2.3. Структура ознак у датасетах кібербезпеки

Одним із ключових аспектів, що визначає ефективність моделей машинного навчання, є структура ознак (feature space). У сучасних датасетах ознаки можна класифікувати за різними критеріями, кожен з яких несе різну інформаційну цінність.

2.3.1 Концептуальна класифікація ознак

У системах виявлення вторгнень (IDS — Intrusion Detection Systems) ознаки, що використовуються для аналізу мережевого трафіку та поведінки систем, умовно поділяються на кілька груп, які відображають різні рівні абстракції даних.

Мережеві ознаки описують базові параметри передавання даних у мережі: кількість пакетів, обсяг переданих байтів, IP-адреси джерела та призначення, порти, тривалість з'єднання. Вони відображають структурні характеристики мережевої взаємодії.

Статистичні ознаки узагальнюють поведінку трафіку у вигляді агрегованих величин: середній розмір пакета, дисперсія розмірів пакетів, частота запитів, ентропія розподілу IP-адрес або портів. Вони дозволяють виявляти аномальні відхилення від нормальної поведінки.

Поведінкові ознаки описують більш високорівневі закономірності активності у часі: регулярність запитів, періодичність з'єднань, послідовності дій, а також шаблони багатокрокових атак (наприклад, розвідка → проникнення → переміщення → ексфільтрація).

Таким чином, IDS використовує багаторівневий опис трафіку — від низькорівневих параметрів до складних поведінкових моделей.

Важливо зазначити, що концептуальна класифікація ознак (мережеві, статистичні, поведінкові) не збігається з їхнім форматом представлення в датасетах (потокові, часові, контентні), оскільки описує різні рівні абстракції аналізу.

2.3.2. Формати представлення ознак у датасетах

Формати представлення ознак та їхні приклади подані у таблиці 2.

Формат ознак	Опис	Приклади	Типи атак
Потокові	Характеристики мережевої сесії	Тривалість, кількість пакетів	DDoS, брутфорс
Статистичні	Агреговані числові значення	Середній розмір пакета	Сканування, ботнет-активність
Часові	Динаміка у часі між подіями	Інтервал між надходженням пакетів	APT, повільні приховані атаки
Контентні	Вміст мережевих даних	HTTP-запити	SQL-ін'єкції, XSS

Табл. 2. Формат представлення ознак та їхні приклади

Також важливо підкреслити, що різні типи атак проявляються через різні групи ознак. Наприклад, DDoS-атаки характеризуються різким збільшенням кількості пакетів за одиницю часу та зменшенням тривалості з'єднань. У той же час APT-атаки можуть не проявлятися через статистичні аномалії, але виявляються через довготривалі поведінкові зміни.

2.3.3. Явище зсуву концепції даних

Зсув концепції даних (concept drift) — це явище, коли статистичні властивості даних, на яких навчається модель машинного навчання, змінюються з часом, через що зв'язок між ознаками (вхідними даними) і цільовою змінною перестає бути стабільним. У результаті модель, яка добре працювала на історичних даних, починає давати гірші результати на нових даних, оскільки її "уявлення" про закономірності більше не відповідає реальності. Це критично впливає на якість моделей, бо призводить до зростання помилок класифікації, зниження точності виявлення атак і деградації загальної ефективності системи.

Основні типи зсуву концепції даних включають **раптовий зсув**, коли розподіл даних різко змінюється (наприклад, поява нового типу атак), **поступовий зсув**, коли зміни відбуваються повільно і непомітно (еволюція поведінки ботнетів або користувачів), а також **періодичний або сезонний зсув**, коли певні патерни повторюються в часі (наприклад, зміни навантаження або активності в різні періоди). Окремо іноді виділяють **інкрементальний зсув**, коли зміни накопичуються поступово без чіткої межі переходу між станами.

У кібербезпеці зсув концепції є особливо критичним, оскільки поведінка атак постійно еволюціонує: з'являються нові варіанти шкідливого трафіку, змінюються техніки обходу систем виявлення, адаптуються ботнети та APT-групи. Це призводить до того, що моделі, навчені на старих даних, швидко втрачають ефективність і можуть не розпізнавати нові типи атак або давати велику кількість хибних спрацювань.

2.3.4. Контентні аномалії та їхня роль у виявленні атак

Аномалії у вмісті мережевих запитів — це відхилення від нормальної структури, семантики або синтаксису даних, що передаються в корисному навантаженні (payload) мережевих пакетів або HTTP/HTTPS запитів. Такі аномалії не завжди проявляються на рівні кількості трафіку чи часових характеристик, але стають помітними при аналізі самого вмісту запитів, який може містити нетипові команди, шкідливі інструкції або ознаки експлуатації вразливостей.

Прикладами таких аномалій є ін'єкції коду у веб-запити, наприклад SQL-ін'єкції, коли в параметри HTTP-запиту вставляються фрагменти SQL-команд для отримання несанкціонованого доступу до бази даних. Іншим прикладом є міжсайтове скриптування (XSS), коли вміст запиту містить шкідливі скрипти, що виконуються у браузері користувача. Також до контентних аномалій належать спроби передачі команд операційній системі через веб-запити або використання нестандартних або зашифрованих структур даних у місцях, де очікується звичайний текстовий або структурований формат. У більш загальному вигляді такі аномалії можуть включати спроби приховування даних у нестандартних HTTP-заголовках, а також використання закодованого вмісту для обходу систем виявлення.

У контексті систем виявлення вторгнень аналіз вмісту запитів дозволяє виявляти атаки, які не проявляються на рівні мережевих метрик, але стають очевидними при перевірці семантики та структури переданих даних.

2.3.5. Обфускація контенту мережевих запитів (кодування URL та подібні техніки)

Закодовані в URL шкідливі дані — це техніка приховування потенційно небезпечного вмісту в мережевих запитах шляхом його кодування у форматі, який відповідає стандарту URL-encoding (percent-encoding). У такому випадку символи, які можуть бути розпізнані як частина атаки або заблоковані фільтрами безпеки, замінюються на їх коди у вигляді послідовностей типу %xx. Це дозволяє передавати ін'єкційні або шкідливі рядки у вигляді, який на перший погляд виглядає як звичайний легітимний HTTP-запит.

Основна мета такого підходу полягає в обході систем захисту, які аналізують трафік на рівні сигнатур або простого текстового співставлення. Оскільки частина IDS або WAF може перевіряти лише "сирий" або частково декодований вміст, закодовані дані дозволяють приховати ключові елементи атаки, такі як SQL-оператори, JavaScript-код або системні команди. Після потрапляння на сервер або у вразливий компонент застосунку такі дані можуть бути автоматично декодовані та виконані в оригінальному вигляді.

У контексті атак це часто використовується для маскування SQL-ін'єкцій, міжсайтового скриптування (XSS) або command injection, коли шкідливі фрагменти коду передаються через параметри URL і проходять базові рівні фільтрації непоміченими. Таким чином, URL-кодування виступає як простий, але ефективний механізм обфускації, який знижує ефективність сигнатурних методів виявлення та ускладнює аналіз трафіку на рівні мережевих систем безпеки.

3. ОГЛЯД СУЧАСНИХ ДАТАСЕТІВ

Створення сучасного датасету є складним багатоступеневим процесом, який включає як технічні, так і методологічні етапи. У загальному вигляді цей процес можна описати як наступна послідовність процесів.

Спочатку створюється контрольоване середовище, у якому моделюється реальна мережа або її частина. Далі генерується нормальний трафік, який імітує поведінку реальних користувачів. Паралельно запускаються сценарії атак, які можуть бути як автоматизованими, так і напівручними. Після цього здійснюється збір мережевих логів, які включають інформацію про пакети, потоки, часові мітки та інші параметри. Наступним етапом є екстракція ознак, тобто перетворення сирих даних у структурований формат, придатний для машинного навчання. Завершальним етапом є розмітка даних (labeling), яка часто виконується або автоматично, або з участю експертів.

Однак на кожному з цих етапів виникають проблеми. Однією з найбільш критичних є упередженість розмітки (labeling bias), коли певні типи атак можуть бути неправильно класифіковані або узагальнені. Іншою проблемою є невідповідність між симульованими атаками та реальними сценаріями, що знижує практичну цінність датасету.

Серед сучасних датасетів, які широко застосовуються у наукових дослідженнях і практичних системах кібербезпеки, особливу увагу слід приділити таким наборам, як CIC-IDS2017, CSE-CIC-IDS2018, UNSW-NB15 та TON_IoT.

Датасет **CIC-IDS2017** (Canadian Institute for Cybersecurity Intrusion Detection System 2017) був створений Канадським інститутом кібербезпеки і є одним із перших масштабних наборів даних, що намагається максимально точно відтворити реалістичний мережевий трафік у сучасному середовищі. Його особливістю є те, що він включає як нормальний трафік, згенерований реальними користувачами, так і різноманітні типи атак, зокрема DDoS (Distributed Denial of Service — розподілена атака відмови в обслуговуванні), brute force (перебір паролів), infiltration (проникнення в систему) та web-атаки. Дані в цьому датасеті представлені у вигляді мережевих потоків, що дозволяє ефективно використовувати їх для задач класифікації та виявлення аномалій. Важливо підкреслити, що CIC-IDS2017 включає часову структуру даних, що дає змогу аналізувати поведінкові патерни у динаміці.

Подальшим розвитком цієї ідеї став датасет **CSE-CIC-IDS2018** (Communications Security Establishment – Canadian Institute for Cybersecurity Intrusion Detection System 2018), який був створений у співпраці між урядовими структурами та науковими установами Канади. Він характеризується значно більшим обсягом даних, більшою різноманітністю атак та використанням більш складної інфраструктури для генерації трафіку. У цьому датасеті враховано сучасні сценарії кіберзагроз, включаючи атаки на веб-додатки, ботнети та експлойти, що дозволяє використовувати його для навчання моделей, орієнтованих на реальні умови функціонування корпоративних мереж. Окрім того, важливою особливістю є більш деталізована структура логів, що дозволяє виконувати мульти-рівневий аналіз.

Ще одним важливим датасетом є **UNSW-NB15** (University of New South Wales – Network-Based 2015), розроблений в Австралії. На відміну від попередніх наборів, цей датасет створювався з використанням сучасних інструментів генерації мережевого трафіку та містить як синтетичні, так і реалістичні компоненти. Він включає дев’ять категорій атак, серед яких exploit, reconnaissance, shellcode та інші, що дозволяє проводити більш детальну класифікацію загроз. Важливою особливістю UNSW-NB15 є ретельно продуманий набір ознак, який включає як базові мережеві параметри, так і статистичні характеристики трафіку.

У контексті розвитку Інтернету речей (Internet of Things, IoT) особливої актуальності набувають датасети, орієнтовані на аналіз поведінки IoT-пристроїв. Одним із таких є **TON_IoT** (Telemetry of Network and IoT), який містить дані не лише мережевого трафіку, але й телеметрію з різних сенсорів, операційних систем і застосунків. Це дозволяє досліджувати кіберзагрози у більш широкому контексті, враховуючи взаємодію між різними рівнями системи.

Характеристики сучасних датасетів подані у таблиці 3.

Датасет	Тип середовища	Кількість атак	Особливості
CIC-IDS2017	Корпоративна мережа	~15	Реалістичний трафік
CSE-CIC-IDS2018	Розширена інфраструктура	>20	Великий обсяг
UNSW-NB15	Гібридне середовище	9	Якісні ознаки
TON_IoT	IoT + мережа	>10	Телеметрія

Табл. 3. Характеристики сучасних датасетів

Важливим аспектом є не лише структура датасету, але й те, як моделі поводяться при його використанні. Різні датасети формують різні статистичні властивості, що безпосередньо впливає на якість класифікації.

Поведінкові характеристики моделей подану у таблиці 4.

Датасет	Поведінка моделі	Причина
NSL-KDD	Перенавчання	Прості патерни
CIC-IDS2017	Висока чутливість	Незбалансованість класів
UNSW-NB15	Стабільність	Якісні ознаки
TON_IoT	Шумність	Iot варіативність

Табл. 4. Поведінкові характеристики моделей

Таким чином, датасет фактично визначає не тільки якість навчання, але й тип помилок, які буде робити модель.

4. ПОВЕДІНКОВІ МОДЕЛІ СУЧАСНИХ КІБЕРЗАГРОЗ

Сучасні кіберзагрози слід розглядати як багаторівневу систему, де тип атаки, її інфраструктура та поведінкова модель є різними осями опису, а не взаємовиключними категоріями. Таким чином, вони є складними багатофазними та багаторівневими поведінковими процеси, які формуються у часі та можуть охоплювати різні рівні мережевої та системної взаємодії. На відмиіну від класичних атак кінця XX століття, сучасні загрози мають адаптивний характер, використовують механізми маскування, імітації легітимної поведінки та розподілення навантаження між великою кількістю вузлів. Саме тому сучасні датасети повинні відображати не лише статичні ознаки, а й динаміку поведінки атакуючих систем.

Перед розглядом особливостей сучасних кібератак варто розглянути деякі статистичні індикатори атак, а саме ентропію та унікальність IP-адрес..

Ентропія IP-адрес — це міра невизначеності або хаотичності розподілу IP-адрес у мережевому трафіку. Вона базується на інформаційній теорії Клода Шеннона і дозволяє кількісно оцінити, наскільки рівномірно або нерівномірно розподілені джерела або отримувачі трафіку.

Якщо трафік походить від невеликої кількості стабільних IP-адрес (наприклад, звичайна робота користувачів або сервісів), ентропія є низькою. Якщо ж трафік надходить від великої кількості різних IP-адрес без стабільної структури, ентропія зростає.

У контексті кібербезпеки висока ентропія IP-адрес часто є індикатором розподілених атак, таких як DDoS або активність ботнетів, де велика кількість вузлів генерує трафік одночасно або в схожих патернах.

Кількість унікальних IP-адрес — це метрика, яка відображає різноманітність джерел або отримувачів мережевого трафіку в певному часовому вікні або мережевому потоці.

У нормальному режимі роботи системи кількість унікальних IP-адрес зазвичай є відносно стабільною та обмеженою, оскільки взаємодія відбувається з типовим набором користувачів або сервісів.

У випадку атак, зокрема DDoS, кількість унікальних IP-адрес різко зростає через участь великої кількості вузлів (наприклад, ботнету), які одночасно генерують трафік до цільової системи. Таким чином, ця ознака використовується як індикатор розподіленої активності та потенційної аномальної поведінки.

Важливо зазначити, що сама по собі ця ознака не є достатньою для класифікації атаки, але є сильною складовою у комбінації з іншими характеристиками, такими як інтенсивність трафіку та тривалість з'єднань.

4.1. Статистичні ознаки мережевого трафіку для виявлення вторгнень

Загалом, ключові відмінності між нормальним і атакуючим мережевим трафіком проявляються насамперед у його статистичних характеристиках, які описують структуру та впорядкованість мережевої активності.

Нормальний трафік зазвичай характеризується відносно стабільною та передбачуваною поведінкою: ентропія IP-адрес є помірною або стабільною, оскільки користувачі взаємодіють із обмеженим набором сервісів; кількість унікальних IP-адрес змінюється поступово і відповідає природній активності користувачів; тривалість з'єднань варіюється, але в середньому відповідає типу сервісу (наприклад, короткі HTTP-запити або середні за часом сесії).

Атакуючий трафік демонструє статистичні аномалії: ентропія IP-адрес часто різко зростає при розподілених атаках (наприклад, DDoS через ботнет), оскільки запити надходять із великої кількості різних джерел; або навпаки може бути аномально низькою при централізованих атаках. Кількість унікальних IP-адрес при атаках зазвичай суттєво збільшується або змінюється неприродно швидко, що відображає або розподілену інфраструктуру, або масове сканування. Тривалість з'єднань також відхиляється від норми: вона може бути дуже короткою при агресивних перевантажувальних атаках або аномально довгою при повільних атаках, що утримують ресурси сервера (наприклад, прикладні low-and-slow сценарії).

Водночас, сучасні кіберзагрози рідко проявляються як одиничні ізольовані події. Натомість вони формують **багатокрокові, розтягнуті у часі процеси**, які складаються з послідовності дій, кожна з яких окремо може виглядати легітимною або незначною.

Розгляд атак як окремих подій (наприклад, один підозрілий запит або один пакет) є недостатнім, оскільки:

- окремі події часто не перевищують порогів детекції;
- зловмисники навмисно "розмивають" активність у часі;
- значущість з'являється лише на рівні **послідовності дій**.

Поведінковий підхід дозволяє аналізувати атаку як **ланцюг подій**, що формує сценарій вторгнення. Наприклад, у випадку APT-атак спостерігається послідовність: розвідка → отримання доступу → закріплення → горизонтальне переміщення → витік даних. Жоден з цих етапів окремо не є критичним, але їх комбінація формує атаку.

Таким чином, сучасні системи виявлення вторгнень переходять від аналізу окремих сигналів до **моделювання поведінкових патернів у часі**, що дозволяє виявляти складні та приховані атаки.

Перейдемо до розгляду поведінкових моделей сучасних кібератак.

4.2. DDoS-атаки (Distributed Denial of Service)

Distributed Denial of Service (DDoS) — це розподілена атака відмови в обслуговуванні, яка здійснюється шляхом одночасного надсилання великої кількості запитів до цільового ресурсу з багатьох джерел. За рівнем впливу виділяють наступні типи DDoS: об'ємні атаки, протокольні атаки та атаки прикладного рівня.

4.2.1. Об'ємні атаки

Цей тип атак спрямований на перевантаження пропускної здатності мережі. Основний патерн — різке збільшення кількості пакетів (packets per second). Типовий приклад — UDP flood, ICMP flood.

4.2.2. Протокольні атаки

Використовують слабкості мережевих протоколів (TCP/IP). Приклад: SYN flood, де атака використовує механізм тристороннього TCP-handshake, надсилаючи SYN-запити без завершення з'єднання.

4.2.3. Атаки прикладного рівня

Найбільш складний тип, оскільки імітує поведінку легітимних користувачів. Приклад: HTTP GET/POST flood, коли запити виглядають «нормальними». Поведінкова модель цього типу атак: різке зростання трафіку, зменшення тривалості сесій, зростання ентропії IP-адрес та однотипність запитів.

Розглянемо практичний приклад того, як DDoS-атака відображається у структурі датасету. Під час нормальної роботи мережі кількість пакетів за секунду є відносно стабільною і коливається у межах певного діапазону. Однак під час DDoS-атаки спостерігається різкий сплеск цього показника, а також значне зменшення середньої тривалості з'єднань. Порівняння нормального трафіку та DDoS-атаки подана у таблиці 5.

Ознака	Норма	DDoS
Кількість пакетів в секунду	100	10000
Тривалість з'єднання	30 с	1–2 с
Кількість унікальних IP-адрес	Низька	Дуже висока
Ентропія IP-адрес	Стабільна	Висока

Табл. 5. Порівняння нормального трафіку та DDoS

З точки зору моделі машинного навчання, така ситуація призводить до зміщення розподілу ознак, що дозволяє класифікатору ідентифікувати аномалію навіть без явного знання типу атаки.

4.3. Ботнет-атаки

Ботнет — це мережа заражених пристроїв (ботів), які керуються централізовано або децентралізовано через командно-контрольні сервери (C&C — Command and Control). Для цього типу атак характерна **періодична сигнальна активність заражених пристроїв (beaconing)**, тобто регулярні, повторювані мережеві звернення інфікованих вузлів до командного центру ботнету або до заздалегідь визначених вузлів керування.

Ідея періодичної сигнальної активності полягає в тому, що після зараження пристрій (бот) не діє одразу активно, але періодично надсилає короткі запити і перевіряє, чи є команди від оператора

ботнету. Типовими характеристиками такої активності є регулярні інтервали (наприклад, кожні 30–300 секунд), невеликий обсяг даних, схожі або ідентичні запити та мінімальна фонова активність.

Періодична сигнальна активність дозволяє ботнетам:

- підтримувати керованість внаслідок координації заражених пристроїв та передачі команд;
- забезпечувати прихованість управління, оскільки трафік виглядає як звичайні періодичні запити;
- перевіряти доступність ботів і формувати карту активних пристроїв;
- готуватися до атак шляхом отримання інструкцій, завантаження шкідливих модулів та очікування сигналу для масової атаки.

Типи архітектури ботнетів наступні: **централізований** та **peer-to-peer (P2P)** ботнет.

У випадку централізованого ботнету управління здійснюється через один або кілька C&C серверів. Натомість, при Peer-to-Peer (P2P) ботнеті відсутній централізований сервер, а кожен бот може бути як клієнтом, так і вузлом управління.

Поведінкова модель: періодичні запити до C&C, стабільні інтервали з'єднань, низька варіативність трафіку, прихована фонова активність.

4.4. Атаки на веб-додатки

Окремо виділяють атаки спрямовані на використання вразливостей веб-застосунків та серверів.

4.4.1. SQL-ін'єкція (SQLi)

SQL Injection — це атака, при якій зловмисник вставляє SQL-код у запити до бази даних.

Поведінкова модель: аномальні символи, різке збільшення помилок сервера, нетипові HTTP запити

4.4.2. Міжсайтове скриптування (Cross-Site Scriptingб XSS)

Cross-Site Scripting — атака, що дозволяє виконувати шкідливі скрипти в браузері користувача.

Поведінкова модель: вставка JavaScript у параметри запиту, підозрілі символи в URL, зміна поведінки сторінки.

4.4.3. Брутфорс

Брутфорс — перебір паролів шляхом автоматизованих спроб входу.

Поведінкова модель: велика кількість запитів авторизації, повторювані IP або ботнет-IP, зростання кількості невдалих спроб авторизації.

4.5. APT-атаки (Advanced Persistent Threat)

Advanced Persistent Threat (APT) — це складні довготривалі цілеспрямовані атаки, які характеризуються прихованістю, багатоступеневістю та високим рівнем організації.

Фази APT наступні:

1. **Розвідка (**Reconnaissance): збір інформації про ціль, а саме IP-діапазони, сервіси, користувачі.
2. **Первинний доступ** (Initial Access)**:** фішинг, експлойти, викрадення облікових даних.
3. **Закріплення** (Persistence): створення бекдорів, зміна системних налаштувань.
4. **Горизонтальне переміщення** (Lateral Movement)**:** поширення всередині мережі.
5. **Витік даних** (Exfiltration): непомітне виведення даних назовні.

Поведінкова модель APT: довгі часові інтервали без активності, низький рівень шуму, складні багатоступеневі переходи, імітація легітимної активності.

APT-атаки є складними для виявлення, оскільки вони не проявляються як різкі або локалізовані аномалії в мережевому трафіку, а формують довготривалі, слабко виражені та багатокрокові поведінкові процеси, які можуть виглядати як нормальна активність системи.

Додатковою складністю є те, що мережеві запити APT часто імітують легітимний трафік, використовуючи стандартні протоколи, такі як HTTP або HTTPS, а також стандартні порти, що ускладнює сигнатурне виявлення і робить їх подібними до звичайної користувацької або сервісної активності.

Важливою характеристикою є також значна розтягнутість у часі, оскільки APT-атаки можуть тривати тижнями або навіть місяцями, і жодна окрема подія не виглядає підозрілою, тоді як атака проявляється лише як сукупність слабких сигналів у довгостроковій перспективі. Крім того, такі атаки є фрагментованими, оскільки їх етапи, включаючи розвідку, проникнення, закріплення, переміщення всередині мережі та витік даних, рознесені у часі та можуть виглядати як незалежні події, що ускладнює їх кореляцію.

Додатковим фактором складності є використання легітимної інфраструктури, наприклад компрометованих серверів або хмарних сервісів, що дозволяє зловмисникам змішувати свій трафік із звичайним і знижує ефективність простих фільтрів. У результаті APT-атаки стають видимими не як одиничні інциденти, а як складні поведінкові сценарії, які можна виявити лише через аналіз кореляцій у часі та побудову моделей нормальної та аномальної поведінки мережевого середовища.

4.6. IoT-специфічні атаки

Інтернет речей створює нову поверхню атак через велику кількість слабко захищених пристроїв.

Типові атаки:

1. Mirai ботнет: один із найвідоміших IoT-ботнетів, що використовує слабкі паролі.
2. Автоматизоване використання вкрадених облікових даних.
3. Експлуатація вразливостей прошивки пристроїв.

Поведінкова модель: масова однотипна активність пристроїв, низька обчислювальна складність запитів, постійні сканування портів, повторювані спроби з’єднання.

4.7. Узагальнення поведінкових моделей сучасних атак

Важливо розуміти, що DDoS, APT і ботнет — це не взаємовиключні категорії, а різні виміри опису кіберінциденту. Вони відповідають на різні питання:

- APT: хто і з якою метою діє (довготривала кампанія);
- DDoS: які дії виконуються (порушується доступність сервісу);
- Botnet: яка технологічна база використовується (інфраструктура заражених пристроїв).

Таким чином, одна й та сама ситуація може одночасно бути APT-кампанією (якщо це довготривала, прихована операція групи), використанням botnet (якщо атака виконується зараженими пристроями) та DDoS-атакою, якщо метою є перевантаження сервісу.

Окремо варто згадати про так звані **«повільні приховані атаки» (low-and-slow)**, які слід розглядати не як окремий клас атак, а як поведінкову модель, яка може використовуватись у різних контекстах, включаючи APT-кампанії, ботнет-активність або прикладні DoS-атаки. Це тип мережевих атак, які характеризуються низькою інтенсивністю, розтягнутістю у часі та навмисним уникненням різких аномалій у трафіку. Їхня основна ідея полягає в тому, щоб залишатися “нижче рівня помітності” для систем виявлення, які зазвичай орієнтуються на пікові навантаження, різкі зміни частоти запитів або перевищення порогових значень. Такі атаки можуть проявлятися як дуже

повільні HTTP-з'єднання, рідкісні запити або поступові дії, що імітують нормальну поведінку користувача чи сервісу.

Ефективність повільних прихованих атак пояснюється тим, що класичні системи виявлення вторгнень часто працюють на основі статистичних або порогових моделей, які добре виявляють масові атаки, але погано реагують на слабкі, розподілені у часі сигнали. У результаті кожна окрема дія атаки виглядає незначною і не перевищує порогів аномальності, однак у сукупності такі дії формують повноцінний сценарій вторгнення. Крім того, ці атаки часто імітують легітимний трафік, використовуючи стандартні протоколи та поведінкові патерни користувачів, що додатково ускладнює їх виявлення. Саме тому вони особливо небезпечні у контексті поведінкового аналізу, оскільки вимагають не аналізу окремих подій, а кореляції та моделювання довготривалих часових залежностей.

Прикладом повільної атаки на HTTP-з'єднання є атака типу Slowloris.

У цьому сценарії зловмисник встановлює велику кількість HTTP-з'єднань із вебсервером, але не завершує формування запитів. Замість швидкого надсилання повного HTTP-запиту він періодично надсилає лише невеликі фрагменти заголовків або даних, підтримуючи з'єднання "живим" якомога довше. Сервер змушений утримувати ці відкриті сесії у своєму пулі ресурсів, очікуючи завершення запитів.

Принцип дії полягає у виснаженні ресурсів сервера не через великий обсяг трафіку, а через тривале утримання максимальної кількості одночасних з'єднань. Оскільки більшість вебсерверів мають обмеження на кількість паралельних з'єднань, легітимні користувачі в результаті не можуть отримати доступ до сервісу, навіть якщо загальний мережевий трафік виглядає низьким.

Цей тип атаки належить до **повільних DDoS-атак прикладного рівня** (application-layer low-and-slow) і є характерним прикладом прихованого виснаження ресурсів, яке важко виявити лише за об'ємними метриками трафіку.

Узагальнені ознаки сучасних кіберзагроз подані у таблиці 6.

Тип атаки	**Основна поведінкова модель**	**Часова поведінка**	**Складність виявлення**
DDoS	Різке зростання трафіку	Короткочасна	Середня
Botnet	Сигнальна активність зараженого пристрою	Періодична	Висока
Атаки на веб-додатки	Відхилення у характеристиках мережевого пакету	Подієва	Середня
APT	Повільні і малопомітні атаки	Довготривала	Дуже висока
IoT	Масові повтори	Стабільна	Висока

Табл. 6. Основні характеристики сучасних кіберзагроз

Загалом, сучасна кіберзагроза не є одноразовою подією, а представляє собою часовий процес:

$Attack = f(t, x_t)$, де

t — час, x_t — стан системи в момент часу.

Таким чином, задача виявлення атак фактично переходить у задачу аналізу часових рядів та поведінкових послідовностей.

Сучасні атаки необхідно розглядати як багатовимірні поведінкові процеси, які не можуть бути ефективно описані лише статичними ознаками. Це прямо впливає на вимоги до датасетів, які повинні містити часову структуру, контекст взаємодії та можливість відображення багатофазних сценаріїв атак. Саме тому сучасні системи виявлення вторгнень переходять від класичних підходів класифікації до моделей аналізу поведінки у часі.

5. ВИСНОВКИ

Таким чином, сучасні датасети для виявлення кіберзагроз є складними, багатовимірними та динамічними структурами даних, які відіграють ключову роль у побудові ефективних інтелектуалізованих систем інформаційної безпеки. Їх правильний вибір і використання визначає не лише якість навчання моделей, але й їхню здатність адаптуватися до нових типів атак і змін у середовищі. Особливо важливо розуміти, що датасет є не просто набором даних, а формалізованою моделлю кіберпростору, яка визначає межі можливостей будь-якої системи машинного навчання. У подальших лекціях буде розглянуто, яким чином ці дані використовуються для побудови моделей, а також які методи дозволяють підвищити їхню ефективність у реальних умовах експлуатації.

6. ПИТАННЯ ДЛЯ САМОКОНТРОЛЮ

1. Що таке набір даних у задачах машинного навчання для кібербезпеки та які вимоги до нього висуваються?
2. Які основні типи ознак застосовуються в системах виявлення вторгнень
3. Які ознаки використовуються для аналізу мережевого трафіку на рівні потоків і що вони описують?
4. Що таке ентропія IP-адрес і яку характеристику мережевого трафіку вона відображає?
5. Що означає кількість унікальних IP-адрес у контексті аналізу мережевої активності?
6. Чому сучасні атаки доцільно розглядати як поведінкові процеси, а не як окремі події?
7. Що таке атака типу DDoS і які її основні класи (об’ємні, протокольні, прикладного рівня)?
8. Які характерні ознаки DDoS-атак у мережевому трафіку?
9. Що таке ботнет і які основні архітектури ботнет-мереж існують?
10. Що таке періодична сигнальна активність заражених пристроїв і яку роль вона виконує в ботнетах?
11. Що таке APT-атака і які її основні етапи життєвого циклу?
12. Чому APT-атаки є складними для виявлення з точки зору поведінки мережевого трафіку?
13. Що таке аномалії у вмісті мережевих запитів і які приклади таких аномалій?
14. Що таке закодовані в URL шкідливі дані і як вони використовуються для обходу систем захисту?
15. Що таке повільні приховані атаки і чому вони ефективні проти систем виявлення?
16. Наведіть приклад повільної атаки на HTTP-з’єднання та поясніть її принцип дії.
17. Що таке зсув концепції даних і як він впливає на якість моделей машинного навчання?
18. Які основні типи зсуву концепції даних існують?
19. Чому зсув концепції даних є критичним у задачах кібербезпеки?
20. У чому полягають ключові відмінності між нормальним і атакуючим трафіком з точки зору статистичних характеристик (ентропія, різноманітність IP-адрес, тривалість з’єднань)?